

Victoria Health Group – GRC Risk Program Simulation

Role: GRC Analyst | Frameworks: NIST SP 800-30, NIST CSF 2.0, ISO 27001:2022, HIPAA, SOC2

Objective: Assess 5 critical risks across 3 acquired hospitals post-M&A

Scope: Risk Register, Appetite Statement, Control Inventory, Vendor Risk, Exec Report

Tools: Google Sheets, NIST/ISO standards

Skills Demonstrated: Risk Assessment & Quantification, ISO 27001 Control Mapping, NIST CSF Implementation, Vendor Risk Management, HIPAA Compliance Analysis, Board-Level Reporting, GRC Documentation, M&A Risk Integration, Audit Readiness

Note: *Scenario-based for portfolio. No PHI used. All frameworks reflect real healthcare audits.*

Victoria Health Risk Register

Risk id	Description	Category	Likelihood	Impact	Inherent Risk Score	Existing controls	Residual Risk Score	Risk Owner	Treatment Plan	Status
R-001: Unpatched Medical IoT Devices	There is a risk that threat actors could exploits unpathced madical IoT devices on patient network due to outdated firmware leading to unauthorised PHI access, patient safety incidents and regulatory penalties under HIPAA.	Cyber	4 - Likely. 47 devices, no patches, 18 months, manufacturer unresponsive.	4 - Major. PHI breach + patient safety + fine \$500K-\$5M USD.	16 Critical	Basic firewall, but no VLAN segmentation for IoT	15 - High. Firewall not designed for IoT lateral movement	Hospital IT Managers - Mysuru, Kolar, Mangalore	Mitigate - 1. Network segmentation for IoT 2. Vendor escalation for patches 3. Compensating control: IDS monitoring	Open
R-002: Inconsistent Password Policies	There is a risk that inconsistent password policies across acquired hospitals due to lack of centralized IAM standards could lead to credential compromise, unauthorized PHI access, and HIPAA violations.	Compliance	4 – Likely. 3 of 4 hospitals have weak/no MFA. Credential stuffing attempts observed in Q1 2026.	4 - Major. PHI breach affects 50K+ patients. Fines \$500K-\$5M USD + patient trust loss.	16 Critical	Mysuru: 12-char + MFA. Kolar: 8-char no MFA. Mangalore: No documented policy.	15 - High. Existing controls only cover 25% of users.	Hospital IT Managers - Mysuru, Kolar, Mangalore	Mitigate - 1. Board-approved Password Standard 2. Enforce MFA on all privileged + remote access 30 days 3. Audit AD monthly	Open
R-003: No Incident Response Plan	There is a risk that the absence of a tested incident response plan across Victoria Health due to post-acquisition gaps could lead to delayed containment of cyber events, resulting in extended outages, regulatory fines for late breach notification, and patient safety impact.	Operational	4 - Likely. The Kolar ransomware scare took 72 hours. No tabletop done. 3 hospitals = 3x attack surface.	5 - Catastrophic. HIPAA breach notification >60 days = fines. System downtime halts surgeries.	20 Critical	Ad-hoc: IT Manager phone tree, firewall logs exist but no SIEM, no on-call rotation	15 - High. Ad-hoc response provides no measurable reduction.	Hospital IT Managers - Mysuru, Kolar, Mangalore	Mitigate - 1. Publish IR Plan + RACI in 30 days 2. Run tabletop with IT + Legal + CMO Q2 3. Implement 24/7 SOC monitoring	Open
R-004: Shared Admin Account Without MFA	There is a risk that a single shared admin account without MFA due to legacy system constraints could lead to full network compromise if credentials leak, causing patient safety system outage and HIPAA breach.	Operational	5 - Almost Certain. Account used daily by 3 teams. Last password change 2022.	4 - Major. Domain admin = all PHI, EHR, billing down.	20 Critical	Password known by 6 staff. No logging.	20 - Critical	Hospital IT Managers - Mysuru, Kolar, Mangalore	Mitigate - 1. Break glass account only 2. Implement the PAM tool within 30 days 3. Enforce MFA on all admins via VPN tunnel 20 days 3. Rotate password weekly.	Open
R-005: Third party billing vendor breach	There is a risk that the MedicareBillingCo vendor breach due to no SOC2 audit could expose \$50K patient PHI records, leading to HIPAA fine >\$240K and reputational damage.	Compliance	4 - Likely. Vendor refused to share audit reports. Last incident in industry 6 months ago.	5 - Catastrophic. Potential HIPAA fines >\\$240K USD + class action exposure.	20 Critical	Contract signed 2023. No right-to-audit clause, no SOC2 Type II.	20 - Critical	CFO - Vendor Management Team	Mitigate - 1. Add a right-to-audit clause for 30 days 2. Get cyber insurance 3. Plan migration to the SOC2 vendor Q3	Open

Risk Appetite

Risk Category	Appetite Level	Source Threshold	Rationale
Patient Safety	Zero	1 unacceptable	Board mandate
Compliance	Low	4 unacceptable	HIPAA fine
Operational	Moderate	9 unacceptable	Sometimes down OK
Financial	Moderate	9 unacceptable	<\$500K without board
Reputational	Low	4 unacceptable	Trust critical

Control Inventory

Control ID	Control Name	Control Type	Nature	Status
C-001	Network Firewall	Preventive	Technical	Partial
C-002	MFA for priviledge	Preventive	Technical	Gap
C-003	Password Policy	Preventive	Admin	Inconsistent
C-004	IR Plan	Corrective	Admin	Gap
C-005	Physical Locks	Preventive	Physical	Gap
C-006	Security Awerness Training	Preventive	Admin	Gap
C-007	SIEM Log Monitoring	Detective	Technical	Partial
C-008	Vendor Due Delligence Process	Preventive	Admin	Gap
C-009	Backup & Restore Tests	Corrective	Technical	Inconsistent
C-010	CCTV for Filing Rooms	Detection	Physical	Gap

Vendor Risk Assessment

Vendor Name	Data Shared	Inheretent Risk	Due Deligence Done	Residual Risk	Decision
MedicareBillingCo	PHI, Billing, SSN	16 - Critical. No SOC2 report provided	Requested ISO 27001 cert. Got nothing	16 - Critical	Suspend data sharing and services within 30 days if the SOC2/ISO 27001 certification is not provided
AWS Cloud Hosting	EHR, PHI, Backups	12 - High. Likelihood 3 x Impact 4. Cloud misconfiguration is common.	Yes – SOC2 Type II, ISO 27001 cert received 2024	6 – Medium after VPC + encryption controls	Accept with quarterly review

Victoria Health Group – GRC Executive Summary

Program Owner: Ambika Samanta, GRC Analyst

1. RISK REGISTER - 5 Critical Risks Identified

Methodology: NIST SP 800-30 Rev 1, 5x5 Matrix

Current State –

- R-001 Unpatched Medical IoT Devices: 4L x 4I = 16 Critical → Residual 15 High
Controls: Basic firewall only, no VLAN segmentation. Lateral movement risk remains.
Impact: PHI breach + patient safety incident + HIPAA fines \$500K to \$5M USD.

- R-002 Inconsistent Password Policies: 4L x 4I = 16 Critical → Residual 15 High
Controls: 12 char + MFA in Mysore only, 8 char no MFA in Kolar, no policy in Mangalore.
Only 25% user coverage. Auth attacks already observed.
Impact: PHI breach affecting 50K+ patients + fines \$500K to \$5M USD + patient trust loss + reputational damage.

- R-003 No Tested Incident Response Plan: 4L x 5I = 20 Critical → Residual 15 High
Controls: Ad-hoc phone tree, firewall logs only. No SIEM, no 24/7 on-call rotation.
Impact: Breach notification >60 days = HIPAA fines. Surgeries stop = patient safety risk.

- R-004 Shared Admin Account No MFA: 5L x 4I = 20 Critical → Residual 20 Critical
Controls: None. Password shared by 6 staff, last changed in 2022, no logging/MFA.
Impact: Full network compromise, PHI/EHR/billing outage, patient safety incident.

- R-005 Third-Party Billing Vendor Breach: 4L x 5I = 20 Critical → Residual 20 Critical
Controls: Contract signed in 2023, but no right-to-audit clause. Vendor refused SOC2 reports.
Impact: 50K patient records exposed. HIPAA fines of up to \$50K per record = \$2M+ total, plus reputational damage.

Key Fields Assessed: Risk ID, Description, Category, Likelihood, Impact, Inherent Risk,
Existing Controls, Residual Risk, Treatment Plan, Status, Risk Owner

2. RISK APPETITE STATEMENT - Board-Approved Thresholds

- 5 risk categories defined with appetite levels per Board mandate and NIST SP 800-30
- Patient Safety: Zero appetite – Threshold 1 unacceptable, no patient harm tolerable
- Compliance: Low appetite – Threshold 4 unacceptable, HIPAA fine exposure limited
- Operational: Moderate appetite – Threshold 9 unacceptable, limited downtime accepted
- Financial: Moderate appetite – Threshold 9 unacceptable, losses <\$500K without Board
- Reputational: Low appetite – Threshold 4 unacceptable, patient trust is critical
- Result: 5 of 5 identified risks exceed appetite, require immediate remediation to meet Board tolerance

3. CONTROL INVENTORY - 10 ISO 27001 Annex A Controls Mapped

- Assessed 10 security controls across technical, administrative, and physical domains.

- Identified critical control gaps in:
 - Multi-Factor Authentication (MFA)
 - Incident Response (IR) Planning
 - Security Awareness Training
 - Vendor Due Diligence

- Existing controls, such as network firewalls and SIEM monitoring are only partially implemented.
- Password governance and backup validation processes were found to be inconsistently enforced.
- Current control maturity indicates foundational security capability, but significant remediation is required to align with ISO 27001 expectations.

4. **VENDOR RISK ASSESSMENT** - 2 Third-Parties Evaluated

- MedicareBillingCo
 - Handles PHI, billing, and SSN data under HIPAA scope
 - Residual Risk: Critical (16) due to missing SOC2 and ISO 27001 evidence
 - No compensating controls validated during assessment
 - Recommendation: 30-day contract remediation window pending certification review
- AWS Cloud Hosting
 - Handles EHR, PHI, and backup infrastructure
 - Provided valid SOC2 Type II and ISO 27001 certifications
 - Residual Risk reduced from High (12) to Medium (6) after VPC and encryption controls validation
 - Recommendation: Accept risk with quarterly technical and compliance reviews

5. **REMEDIATION & TARGET STATE** - Target State to Achieve Board Appetite per NIST CSF

- Objective: Reduce all 5 critical risks to Residual ≤ Board Threshold within 90 days via NIST CSF 2.0 framework
- 30-Day – IDENTIFY & PROTECT: Address immediate Patient Safety and Compliance breaches
 - Action 1: Enforce MFA for privilege on all domain admin accounts. Owner: CISO. Resolves R-004 Gap
 - Action 2: Pause the MedicareBillingCo contract pending SOC2/ISO 27001. Owner: Procurement. Resolves R-005 Gap
 - Action 3: Segment medical IoT network + deploy emergency firewall rules. Owner: Network. Resolves R-001 Partial
- 60-Day – DETECT & RESPOND: Establish monitoring and response capability
 - Action 4: Finalise and test Incident Response Plan with HIPAA breach workflow. Owner: GRC. Resolves R-003 Gap
 - Action 5: Tune SIEM use cases for PHI access + privilege escalation alerts. Owner: SOC. Reduces detection time
 - Action 6: Enforce Password Policy + implement Security Awareness Training for clinical staff. Owner: HR/IT
- 90-Day – RECOVER & GOVERN: Validate recovery and sustained compliance
 - Action 7: Execute quarterly Backup & Restore tests with RTO/RPO validation. Owner: Infrastructure
 - Action 8: Deploy physical access controls + CCTV for filing rooms. Owner: Facilities
 - Action 9: Re-assess all risks post-remediation. Target: 100% risks within Board appetite. Owner: CRO
- Result: Target State = Patient Safety Residual ≤1, Compliance Residual ≤4, Operational/Financial ≤9.
- Achieves ISO 27001 Annex A control coverage >80%, SOC2 Type II readiness for vendors, and HIPAA Breach Notification Rule compliance. Board risk appetite met across all categories by Day 90

Note: Victoria Health is a scenario-based simulation. All frameworks reflect NIST 800-30 & ISO 27001 standards used in real healthcare audits.